Challenge CTI — Helios Energy

Nommer l'attaquant est facile ; le prouver, beaucoup moins

Introduction du sujet

Helios Energy, fournisseur d'énergie fictif de 3000 salariés et opérateur d'importance vitale, vient de subir une intrusion. Le SOC vous remet un dossier brut : 40 indicateurs de compromission, 12 alertes SIEM, 3 binaires suspects, un mémo technique. À vous d'identifier l'attaquant, de reconstituer sa chaîne d'attaque, d'évaluer l'impact et de livrer un rapport de renseignement exploitable.

Le renseignement sur les menaces se décline sur trois niveaux — stratégique pour la direction, opérationnel et tactique pour le SOC — et il ne vaut que par sa rigueur : une attribution juste mais mal argumentée ne tient pas. Tout votre raisonnement doit s'appuyer sur les artefacts, jamais sur un rapport public recopié.

Ce qui vous est fourni

Le SOC d'Helios Energy vous remet un dossier d'artefacts. Vous ne partez pas d'une page blanche : tout votre raisonnement s'appuie sur ces éléments.

- **40 indicateurs de compromission bruts :** empreintes de fichiers, adresses IP, noms de domaine.
- **12 alertes du SIEM :** remontées pendant l'incident.
- **3 binaires suspects :** récupérés sur les postes touchés.
- **un mémo technique initial :** rédigé par l'équipe SOC.

Helios Energy est une entreprise fictive : vous ne trouverez rien à son sujet en ligne, et c'est normal. Votre recherche porte sur l'attaquant, pas sur la victime. Partez des artefacts, identifiez les techniques employées, puis cherchez quels groupes connus les utilisent. C'est le sens de la contrainte qui vous interdit de recopier des techniques depuis un rapport public.

Cadre

- **Durée et organisation :** 5 jours (35 h), en équipe de 2 ou 3.
- **Partie obligatoire — 8 Go :** le travail est mené sur les machines des étudiants, aucune instance n'est fournie. MISP est la plateforme de renseignement du sujet : il tourne en conteneur local pour environ 2 Go, et chaque membre de l'équipe peut le monter. Le graphe se produit depuis votre bundle, avec la bibliothèque Python networkx ou en important le

JSON dans Gephi. Docker et Tor Browser suffisent ; aucune machine virtuelle n'est nécessaire.

- **Partie optionnelle — 16 Go :** le membre disposant d'au moins 16 Go déploie un Wazuh mono-nœud, environ 4 Go, qui cohabite avec MISP, et traite le volet Validation des règles décrit dans le Rendu. Les équipes sont constituées pour qu'au moins une machine le permette. Ce volet ne conditionne pas la validation du projet.
- **Découverte :** la démonstration publique d'OpenCTI permet de voir un graphe abouti et de comprendre le modèle de données. Elle sert à découvrir, pas à produire : OpenCTI n'est pas déployable sur 8 Go, sa pile Elasticsearch, Redis, RabbitMQ et MinIO dépassant la contrainte.
- **Cadre dark web :** consultation et capture uniquement. Acheter un échantillon pour confirmer une fuite constitue un recel ; toute interaction avec un vendeur est proscrite, elle vous expose et compromet la recevabilité de vos preuves. Chaque consultation est horodatée et tracée.
- **Ordre de travail conseillé :** J1 cadrage et triage des artefacts. J2 corrélation et enrichissement dans MISP. J3 reconstitution de la chaîne d'attaque et recherche d'attribution. J4 rédaction des rapports et règles Sigma. J5 notes réglementaire et de partage, graphe, soutenance.
- **Rôle des formateurs :** les formateurs jouent le commanditaire. Ils répondent aux questions de périmètre et d'arbitrage, pas aux questions d'outil.

Votre mission

- **Collecter et corréler les indicateurs :** empreintes, adresses IP, domaines, certificats, depuis les artefacts et des sources ouvertes.
- **Structurer le renseignement dans MISP :** objets, relations, galaxies d'acteurs, taxonomies et tags TLP, pour produire un bundle STIX 2.1 d'au moins 25 objets liés.
- **Cartographier l'attaque :** rattacher les techniques observées à MITRE ATT&CK et au Diamond Model, en les validant depuis les artefacts.
- **Attribuer :** argumenter le groupe ou le cluster avec un niveau de confiance selon l'Admiralty Code, en exposant les biais possibles.
- **Restituer sur deux niveaux :** un rapport stratégique pour la direction et un rapport tactique pour le SOC, chacun adapté à son lecteur.

Compétences visées

- Suivre et analyser les données issues de la veille technologique
- Présenter les préconisations du projet SI et de ses spécifications pour proposer des solutions pérennes et écoresponsables
- Recommander des solutions en s'appuyant sur les résultats de la veille
- Synthétiser les données de veille en validant leur fiabilité et en faire une restitution compréhensible aux acteurs du projet.
- Coordonner la communication entre les parties prenantes

- Développer et intégrer des stratégies de mitigation des risques en identifiant et évaluant les menaces potentielles afin de gérer la sécurité du projet.
- Rédiger et exécuter les scénarios de tests pour détecter et corriger les erreurs et garantir la qualité de l'application
- En réponse à une demande interne ou externe, cartographier les risques de sécurité du SI affectant la confidentialité, l'intégrité ou la disponibilité des actifs afin de mettre en évidence les vulnérabilités et les risques.
- Structurer et mener une analyse approfondie d'un système d'information après une intrusion ou une attaque informatique, en utilisant des techniques de \"forensic\" pour examiner les preuves, identifier les vulnérabilités exploitées, et déterminer l'impact d'un potentiel incident

Quelques pistes pour démarrer

- Monter MISP : le projet officiel github.com/MISP/misp-docker se déploie en conteneur ; comptez environ 2 Go
- Trier avant de corréler : classer les 40 indicateurs par type et par cote de fiabilité Admiralty avant de les charger dans MISP
- Analyser les binaires sans les exécuter : leurs empreintes sur des sources publiques, et si vous poussez, Ghidra pour le désassemblage et Volatility pour la mémoire
- Produire le graphe : exporter le bundle STIX depuis MISP, puis le dessiner avec la bibliothèque Python networkx ou en l'important dans Gephi

- ➔ Nommer les techniques : la matrice attack.mitre.org, et le Diamond Model pour relier adversaire, infrastructure, capacité et victime
- ➔ Coter chaque source : l'Admiralty Code (fiabilité A-F, crédibilité 1-6) donne un langage commun pour dire ce que vaut une information
- ➔ Se référer aux sources officielles : la documentation MISP, la spécification STIX 2.1 et la documentation Wazuh pour le volet 16 Go

Rendu

Un dépôt Git nommé cti-helios-energy rassemble le bundle, les rapports et les notes. Chaque objet STIX porte sa source et sa date de collecte.

- Note de cadrage (2 pages, fin de J1) : périmètre de l'investigation et ce qui en est exclu, hypothèses de départ, sources envisagées, planning des 5 jours, répartition dans l'équipe

- Rapport stratégique pour la direction (PDF, 2-3 pages) : synthèse orientée risque, vulgarisée

- Rapport tactique pour le SOC (PDF, 8-12 pages) avec au moins 10 règles Sigma déployables

- Bundle STIX 2.1 (JSON) incluant tous les objets et leurs relations

- Graphe du renseignement (PNG ou PDF) généré depuis votre bundle, faisant apparaître l'acteur, ses outils, ses indicateurs et leurs relations

- Note d'attribution : argumentation du groupe ou cluster, niveau de confiance Admiralty, biais potentiels

- Matrice de risques CID : pour chaque actif touché, l'impact sur la confidentialité, l'intégrité et la disponibilité, avec criticité argumentée

- Note réglementaire à l'ANSSI (1 page) : Helios Energy est opérateur d'importance vitale. Qualifier l'incident, indiquer ce qui doit être déclaré, à qui et dans quel délai

- Note de partage communautaire (1 page) : ce qui peut être partagé et sous quelle classification TLP, ce qui reste interne, et pourquoi

- Partie optionnelle (16 Go) : validation des règles de détection — déployer un Wazuh mono-nœud, y rejouer les journaux fournis, convertir les règles Sigma en règles Wazuh et les tester. Un tableau par règle : déclenche-t-elle sur l'attaque, combien de faux positifs, quel ajustement

- Soutenance (20 min + 10 de questions) devant la direction et le responsable SOC, avec défense de l'attribution et de son niveau de confiance

Ce qui fait la différence

- **Argumenter, pas affirmer :** nommer un groupe célèbre sans preuve est le piège classique. Une attribution prudente — un cluster, une confiance moyenne — vaut mieux qu'un nom affirmé sans fondement.
- **Partir des artefacts :** chaque technique citée doit se rattacher à un artefact du dossier. Une technique recopiée d'un rapport public, sans trace dans les artefacts, ne compte pas.
- **Écrire pour chaque lecteur :** la direction et le SOC n'attendent pas la même chose. Un seul rapport pour les deux échoue : vulgarisez pour l'une, détaillez pour l'autre.

Glossaire

- **IoC :** indicateur de compromission : une trace observable laissée par une attaque — empreinte d'un fichier, adresse IP, nom de domaine.
- **TTP :** tactiques, techniques et procédures : la façon de faire d'un attaquant, plus difficile à changer qu'une adresse IP, donc plus utile pour l'attribution.
- **STIX 2.1 :** format normalisé de description du renseignement, pour qu'un outil l'échange avec un autre ; TAXII est le protocole qui le transporte.
- **Admiralty Code :** échelle militaire à deux axes : fiabilité de la source de A à F, crédibilité de l'information de 1 à 6.

- **Diamond Model :** modèle à quatre sommets — adversaire, infrastructure, capacité, victime — qui force à relier ces dimensions.
- **TLP :** convention de diffusion : ROUGE destinataires nommés, ORANGE organisation, VERT communauté, BLANC public.
- **Cluster :** groupe d'activités malveillantes rattachées à un même acteur ; plus honnête que de nommer un groupe connu quand les preuves manquent.